Gift of the Givers · Relief Management System

DELIVERABLE 01

Product Requirements

What the Relief Management System must do, for whom, and how we know each requirement is met.

DOCUMENT	VERSION	DATE	STATUS
D-01	2.0	2026-11-02	Current — reflects the system after audit remediation

CONTENTS

1. Purpose and vision
2. Users and roles
3. Scope
4. Functional requirements
5. Business rules
6. Non-functional requirements (summary)
7. Assumptions, constraints and open questions
8. Glossary

1. Purpose and vision

The Relief Management System supports a humanitarian non-profit (modelled on the Gift of the Givers Foundation) in three areas:

1. **Raising money transparently.** The public can donate online. Every rand shown as "raised" can be traced to a confirmed payment or a staff-recorded offline contribution.
2. **Mobilising people.** Volunteers apply online. Staff review them and assign them to relief projects.
3. **Accountability to donors.** Donors see their history and download donation certificates for confirmed gifts.

> **Product principle — honesty over polish.** The system never shows a figure, status or document it cannot back with data. Unpaid donations are labelled as such, demonstration content is labelled as demonstration, and statistics are computed from the database.

Context

The project is an academic deliverable (Portfolio of Evidence, "Section B" ERD). It is hosted publicly as a demonstration and uses a real NGO's name for illustration. It is **not affiliated** with that organisation. Payments use the PayFast sandbox until real merchant details are configured.

2. Users and roles

Persona	Role	Goals	Key needs
Public visitor	Anonymous	Learn about projects, give, volunteer, ask a question	Fast, mobile-friendly pages; clear trust signals; no account required to donate
Donor	`Donor` (self-registered)	Track donations, download certificates	Accurate history; certificates only for real payments; privacy
Staff member	`Employee` (granted by staff)	Run projects, review volunteers, oversee donations	Accurate totals; filters and exports; audit trail; no accidental data exposure
Information Officer	Organisation (offline)	Answer privacy requests (POPIA)	Privacy notice, consent records, data export/deletion
PayFast	External system	Notify payment results	Reachable, idempotent webhook

Role rules:

- Self-registration always creates a **Donor**. Staff access is granted only by an existing employee (*Staff Access* page) or by the deployment configuration `StaffAccess:BootstrapEmployeeEmails`.
- One account may hold both roles.

3. Scope

In scope (current release)

- Public information pages, live impact figures, project listing with funding progress.
- Online donations in ZAR, USD and EUR, paid through PayFast in rand.
- Donation receipts, donor dashboard and history, donation certificates (HTML + PDF).
- Volunteer applications, review, approval/rejection and assignment to projects.
- Contact inquiries and their handling.
- Staff management of projects, project updates, offline funds and funding reconciliation.
- Staff access management and an audit log.
- Privacy notice and consent capture.

Out of scope (this release)

- Automatic recurring billing. Monthly *pledges* are recorded, but each payment is made separately.
- Live exchange rates (rates are configured).
- Native mobile apps (the site is responsive).
- Multi-organisation or multi-tenant use, and multiple languages.
- Accounting and general-ledger integration.

4. Functional requirements

Priority uses MoSCoW: **M**ust, **S**hould, **C**ould. Status reflects verified behaviour on 2026-11-02 (see the audit addendum).

4.1 Public site

ID	Requirement	Priority	Acceptance criteria	Status	Evidence
FR-01	Show active relief projects with funding progress	M	Projects list shows title, location, status, raised vs goal in rand; progress capped at 100% visually	Done	`HomeController.ReliefProjects`, smoke test
FR-02	Show impact figures computed from live data	M	No hard-coded statistics; figures update when data changes	Done	`ImpactStatsViewComponent` ; test `HomePage_ShowsLiveFiguresInsteadOfHardCodedStatistics`
FR-03	Publish a privacy notice	M	Notice explains data, purposes, sharing, retention, rights, cookies	Draft	`Views/Home/Privacy.cshtml` ; legal review pending (F-09)
FR-04	Contact form	M	Required name, email, subject, message, consent; stored; confirmation page	Done	test `Contact_RecordsConsentTimestamp`

4.2 Donations and payments

ID	Requirement	Priority	Acceptance criteria	Status	Evidence
FR-10	Donate without an account	M	Anonymous donors can donate; signed-in donors' gifts are linked to their account	Done	`DonationService.CaptureAsync`
FR-11	Choose currency ZAR / USD / EUR	M	Foreign amounts converted to rand at the configured rate; both values stored and shown	Done	test `Donate_ForeignCurrency_IsChargedInRandAtConfiguredRate`
FR-12	Pay securely through PayFast	M	Donor redirected to PayFast with signed fields; card data never touches our servers	Wired	smoke test redirect; end-to-end blocked by F-23
FR-13	Only confirmed payments count	M	Project totals, dashboards and certificates include only `Verified` donations	Done	tests `Donate_RecordsPendingDonation_…`, `Notify_Complete_…`
FR-14	Payment confirmation is safe to repeat	M	Duplicate or replayed notifications never add money twice; wrong amount or merchant is refused	Done	tests `Notify_*`
FR-15	Double-submission safe	M	Submitting the same form twice creates one donation	Done	test `Donate_SameIdempotencyTokenTwice_CreatesOneDonation`
FR-16	Receipt page with live status	M	Found by unguessable reference; shows amount, rand value, project, status	Done	test `Receipt_IsFoundByReferenceNotSequentialId`

ID	Requirement	Priority	Acceptance criteria	Status	Evidence
FR-17	Donations only to active projects	M	Suspended or completed projects are rejected with a message	Done	test `Donate_ToSuspendedProject_IsRejectedWithMessage`
FR-18	Monthly pledge	S	Pledge recorded and clearly described as not auto-billed	Pledge only	F-37; billing in the roadmap
FR-19	Anonymous donation option	S	Name hidden on certificates and staff reports	Done	`TaxCertificatePdf.DonorDisplayName`

4.3 Donor portal

ID	Requirement	Priority	Acceptance criteria	Status	Evidence
FR-20	Donor dashboard	M	Confirmed count and rand total, pending count, recent donations with status	Done	`DonorController.Dashboard`
FR-21	Donation history and details	M	Only the donor's own donations; status visible	Done	ownership filter in queries
FR-22	Donation certificate (HTML + PDF)	M	Only for `Verified` donations owned by the donor (or staff); marked *demonstration* until PBO details are configured	Done	test `Certificates_OnlyForOwnersOfVerifiedDonations`
FR-23	Account self-service	S	Change password, download or delete personal data	Done	ASP.NET Identity default UI

4.4 Staff portal

ID	Requirement	Priority	Acceptance criteria	Status	Evidence
FR-30	Manage relief projects	M	Create/edit title, description, location, status, dates, goal, offline funds, image URL; date and amount validation	Done	test `EditingOfflineFunds_AdjustsTotalByTheDifference`
FR-31	Post project updates	S	Create/edit updates per project	Done	`EmployeeController`
FR-32	Review volunteers	M	Filter by status, view details, approve or reject; applicant notified by email when configured	Done	`SetVolunteerStatusAsync`
FR-33	Assign volunteers to projects	S	Only approved volunteers to active projects; no duplicate assignments	Done	`AssignVolunteer`, unique index
FR-34	Donation oversight	M	Filter by status, paged list, rand totals of paid donations, CSV export	Done	`Donations`, `ExportDonations`
FR-35	Funding reconciliation	M	Per project: offline + verified vs recorded; recalculate or accept the difference as offline, both audited	Done	test `FundingReconciliation_RecalculateUsesOfflinePlusVerifiedOnly`
FR-36	Inquiries	S	Open first, mark handled	Done	`Inquiries`

ID	Requirement	Priority	Acceptance criteria	Status	Evidence
FR-37	Staff access management	M	Grant by email to an existing account; revoke others (not self); audited	Done	test `StaffAccess_GrantIsAuditedAndSelfRevokeIsRefused`
FR-38	Audit log	M	All staff changes, access changes, payment events, exports and certificate access, with actor and details	Done	`AuditService` ; test `Notify_Complete_…` asserts `PaymentVerified`

4.5 Volunteers

ID	Requirement	Priority	Acceptance criteria	Status	Evidence
FR-40	Apply to volunteer	M	Name, email, skills, availability required; phone, city, DOB and emergency contact optional; consent required; nothing invented	Done	tests `Volunteer_*`
FR-41	Age check	S	A date of birth, if given, must be at least 16 years ago	Done	`HomeController.Volunteer`

5. Business rules

ID	Rule
BR-01	A project's **raised** figure = offline funds (staff-recorded) + rand value of its **Verified** donations. Nothing else changes it.
BR-02	A donation is `Pending` from submission until a validated PayFast notification marks it `Verified` (COMPLETE) or `Failed` (any other status).
BR-03	PayFast is charged the rand amount: `AmountZar = round(Amount × rate, 2)`, where the rate is stored with the donation.
BR-04	A certificate exists only for a `Verified` donation. It is visible to its owner and to staff. Anonymous donations show "Anonymous Donor".
BR-05	Certificates are labelled *demonstration* until `Organisation:PboReference` is set and `Organisation:IsDemo` is false.
BR-06	Public registration never grants staff access.
BR-07	Every staff change to data or access is written to the audit log in the same transaction.
BR-08	Personal data is collected only with recorded consent (timestamp per record).
BR-09	Single-donation limit: 1 to 1,000,000 in the chosen currency.

6. Non-functional requirements (summary)

The details, targets and verification methods are in 02 — Technical Requirements.

Area	Requirement
Security	Role-based access enforced on the server; anti-forgery; rate limiting; security headers; no secrets in source
Privacy	POPIA-aligned notice, consent, minimisation, export and deletion
Reliability	Idempotent payments; concurrency-safe totals; health probes
Usability	Responsive (mobile first for public pages); accessible forms (WCAG 2.2 AA target)
Maintainability	Automated tests on every critical path; CI gates; documented setup

7. Assumptions, constraints and open questions

Type	Item
Assumption	The organisation will provide a PayFast merchant account, PBO number and Information Officer before going live.
Constraint	PayFast settles only in rand.
Constraint	Hosting on Azure App Service, with Azure SQL.
Open question	Retention periods for donation, volunteer and inquiry data (draft values in the privacy notice).
Open question	Should monthly pledges become PayFast subscriptions (needs product and legal sign-off)?
Open question	Which exchange-rate source is authoritative for foreign donations?

8. Glossary

Term	Meaning
ITN	PayFast *Instant Transaction Notification*: a server-to-server POST that reports a payment result
PBO	Public Benefit Organisation (South African tax status that enables section 18A certificates)
Offline funds	Money raised outside the website (cash, grants, pledges) and recorded by staff
Verified	A donation whose payment PayFast has confirmed
POPIA	Protection of Personal Information Act, 2013 (South Africa)